



Otizm Destek Platformu

Profesyonel Yayına Geçiş, Güvenlik ve Maliyet Raporu

Kod incelemesi · Güvenlik · Erişilebilirlik · Güncel maliyet araştırması

15 Temmuz 2026

İçindekiler

Yönetici Özeti

1. Teknik İnceleme
2. Demo Seviyesinden Profesyonel Yayına Geçiş
3. Otizm Platformuna Özel Güvenlik ve Gizlilik
4. Erişilebilirlik
5. Fiyat Araştırması Yöntemi
6. Frontend Yayınlama
7. Backend Sunucu Maliyeti
8. PostgreSQL Maliyeti
9. Alan Adı ve DNS
10. SSL, CDN, WAF ve Bot Koruması
11. Dosya ve Görsel Depolama
12. E-posta, Push ve Yapay Zekâ

13. Kimlik Doğrulama

14. Yönetim Paneli

15. Analitik, Loglama ve Hata Takibi

16. SEO, Performans ve Mobil

17. Yedekleme ve Felaket Kurtarma

18. Test ve Yayın Süreci

19. Önerilen Yapının Toplam Maliyeti

20. Üç Bütçe Senaryosu

21. Satın Alma Kararı

22. Adım Adım Yayın Planı

23. Nihai Öneri

Araştırmanın Sınırları

Resmî Kaynaklar

Rapor tarihi: 15 Temmuz 2026

Fiyat tarihi: 15 Temmuz 2026

Kur: TCMB 14.07.2026 döviz satış kuru — **1 USD = 47,0098 TL, 1 EUR = 53,5755 TL**

İncelenen kaynak: /Users/eneskotay/Development/Otizm çalışma ağacı

Kapsam: Kod incelemesi, yayın mimarisi, güvenlik/KVKK, erişilebilirlik, resmî sağlayıcı fiyatları ve üç bütçe senaryosu

Bu rapor kod tabanında gerçekten görülen özellikleri esas alır. Paylaşım metnindeki GitHub ve demo bağlantıları boş bırakıldığı için uzak branch/canlı ortam incelemesi yapılmamıştır. Hukuki, tıbbi ve muhasebesel görüş değildir.

Yönetici Özeti

Proje basit bir demo değildir: React 19/Vite 8 frontend, Java 21/Spring Boot 3.3.5 backend, PostgreSQL/Flyway V1–V48, Redis, JWT, rol yönetimi, WebSocket, FCM/Web Push, yönetim paneli, yapay zekâ, dosya depolama, veri dışı aktarma/silme ve test altyapısı vardır.

Kod tarafındaki başlıca yayın engelleri bu çalışma ağacında kapatılmıştır: genel kayıttan rol yükseltme engeli, e-posta/uzman doğrulama, HttpOnly refresh cookie, origin kontrolü, Turnstile ve rate limit, sağlık/gelişim alanlarında AES-256-GCM şifreleme, özel R2/S3 dosya saklama, sahiplik/kapsam denetimi, hesap dışı aktarma/silme, şifreli yedekleme, güvenli hata/correlation ID, SEO ve erişilebilirlik regresyonları.

Yayından önce kalan kritik işler çoğunlukla operasyondur: production hesap ve anahtarları, DNS/TLS, admin MFA, off-site yedek ve restore tatbikatı, izleme alarmları, manuel ekran okuyucu testi, bağımsız güvenlik testi ve KVKK hukuk onayı.

Önerilen sabit altyapı: Cloudflare Pages + Hetzner CX33 + DigitalOcean Managed PostgreSQL + private Cloudflare R2. AI ve opsiyonel analitik hariç yaklaşık **1.247 TL/ay, 14.961 TL/yıl** (vergi ve insan emeği hariç). Minimum tek-VPS yapı yaklaşık **374 TL/ay eşdeğerine** iner, ancak daha büyük tek arıza alanı yaratır.

1. Teknik İnceleme

1.1 Frontend

Alan	Koddan tespit
Ana teknoloji	React 19.2.4, React DOM 19.2.4, Vite 8.0.4, TypeScript 6.0.2, TailwindCSS 4.2.2
Mimari	Client-rendered SPA; SSR/Next.js yok; sayfalar lazy-load ediliyor
Routing	React Router DOM 7.14.1; public, authenticated, role ve admin rotaları
Sunucu durumu	TanStack React Query 5.99.2
Yerel durum	Zustand 5.0.12

Alan	Koddan tespit
Form/doğrulama	React Hook Form 7.72.1, Zod 4.3.6, Hookform resolvers
API	Axios 1.15.1; kök adres ortam değişkeniyle ayrılmalı
Gerçek zamanlı	STOMP + SockJS; mesaj/bildirim akışları
Grafik/yardımcı	Recharts, date-fns, QR code, Lucide icons
PWA/push	Manifest, service worker, offline sayfası, VAPID/Web Push
Test	Vitest, Testing Library, Playwright, axe-core

Oturum yaklaşımı doğru yöndedir: access token yalnız bellekte; dönen refresh token `HttpOnly`, `Secure` production cookie ve `SameSite=Strict` ile saklanır. Refresh/cookie yazan isteklerde origin doğrulaması vardır. Token veya hassas veri `localStorage` 'a dönmemelidir.

Responsive yapı Tailwind mobile-first yaklaşımındadır. Rota odağı, reduced-motion, alt metinler ve form etiketleri iyileştirilmiştir. Yine de gerçek iOS/Android cihaz, ekran büyütme, düşük bant genişliği ve VoiceOver/NVDA testi otomasyonla ikame edilemez.

1.2 Backend

Alan	Koddan tespit
Platform	Java 21, Spring Boot 3.3.5, Maven
Mimari	Controller / Service / Repository / DTO / Model / Security / Config katmanları
API	REST + tutarlı response modelleri; SpringDoc OpenAPI/Swagger admin erişimli
Kimlik	Spring Security, stateless JWT (<code>jwt</code> 0.12.6), BCrypt, method security
Roller	PARENT, EXPERT, ADMIN, TEACHER; genel kayıt admin/teacher veremez
Veritabanı	PostgreSQL, JPA/Hibernate, HikariCP, Flyway V1–V48; <code>ddl-auto=validate</code> , <code>open-in-view=false</code>
Cache/limit	Redis; Redis yoksa kontrollü in-memory fallback
Dosya	Development yerel disk; production private S3/R2; UUID, sahiplik/kapsam, MIME/uzantı/magic-byte ve 10 MB sınırı
E-posta	Sağlayıcıdan bağımsız Spring Mail SMTP
Push	Firebase Admin SDK ve Web Push/VAPID
AI	Google Gemini servis katmanı; chatbot, içgörü ve taslak akışları
Gözlem	Actuator, Micrometer, Prometheus, correlation ID

Merkezi hata yönetimi kullanıcıya stack trace/hassas ayrıntı döndürmez. Rate limiting, Turnstile, proxy IP güven zinciri ve production secret kontrolleri mevcuttur. En önemli kalan kimlik işi admin hesaplarında MFA'dır.

1.3 Veritabanı ve hassas veri

- PostgreSQL şeması Flyway ile sürümlüdür; V15 operasyonel indeksler, V43–V48 dosya güvenliği, hassas kolon şifreleme, hesap silme, e-posta doğrulama ve legacy geçişleri içerir.
- Parolalar BCrypt'tir. Seçili sağlık/gelişim metin/JSON alanları sürümlü AES-256-GCM converter'larıyla uygulama katmanında şifrelenir; anahtar rotasyonu ve backfill vardır.

- `User-Child-Development/Screening/Medication/Message/ClinicalDataShare` gibi ilişkiler gerçek sağlık/çocuk verisi riskini doğurur.
- Dosyalar DB'ye BLOB olarak değil, nesne anahtarı ve yetki metadata'sıyla kaydedilmelidir; mevcut R2/S3 yaklaşımı bunu destekler.
- DB büyümesi kullanıcı sayısından çok mesaj, ölçüm, audit ve rapor sıklığına bağlıdır. `pg_stat_statements`, yavaş sorgu planları ve indeks kullanımı aylık izlenmelidir.

1.4 Kodda bulunan dış servisler

Servis	Kullanım	Kodda durum
Google Gemini	Chatbot, AI içgörü, BEP/taslak işlevleri	Var
Firebase Cloud Messaging	Push bildirim	Var
Web Push/VAPID	Tarayıcı push	Var
SMTP	Doğrulama, parola sıfırlama ve bildirim e-postası	Var; sağlayıcı bağımsız
S3 uyumlu nesne depolama	Kullanıcı dosyaları/raporlar	Var; R2 öneriliyor
Harita API	Harici sağlayıcı	Tespit edilmedi
Google/sosyal giriş	OAuth login	Tespit edilmedi
Ödeme	Ödeme altyapısı	Tespit edilmedi
Analitik/Sentry	Kullanıcı analitiği ve hata SaaS'ı	Kod entegrasyonu tespit edilmedi; production işi

2. Demo Seviyesinden Profesyonel Yayına Geçiş

Alan	Mevcut durum	Kalan sorun / risk	Yapılması gereken	Öncelik
Kimlik/roller	JWT, cookie refresh, method security, uzman onayı	Admin MFA yok	TOTP/WebAuthn, kurtarma ve alarm	Kritik
Hassas veri	AES-GCM + rotasyon/backfill	Anahtar operasyonu ve backfill kanıtı	Vault, erişim kaydı, rotasyon tatbikatı	Kritik
Dosya	Private R2/S3 ve yetki metadata'sı	Production bucket/AV taraması operasyonel	Hesap aç, lifecycle, malware scan, negatif test	Kritik
KVKK/çocuk	Rıza alanları, dışa aktarma/silme	İşleme şartı, saklama, yurt dışı aktarım onaysız	Avukat/KVKK uzmanı ve veri envanteri	Kritik
AI	İşlevler var, tıbbi uyarılar eklendi	Hassas prompt ve ücretsiz katman riski	Minimizasyon, ücretli şartlar, harcama limiti	Kritik
Yedek	Şifreli backup/restore scriptleri	Off-site hedef ve restore kanıtı yok	Farklı sağlayıcı + 3 aylık tatbikat	Kritik
Gözlem	Prometheus/correlation ID	Sentry/uptime alarm hesapları yok	PII scrub ile bağla, test alarmı	Yüksek
Erişilebilirlik	Axe e2e, rota odağı, reduced-motion	Manuel ekran okuyucu testi yok	NVDA/VoiceOver ve gerçek mobil test	Yüksek

Alan	Mevcut durum	Kalan sorun / risk	Yapılması gereken	Öncelik
CI/CD	GitHub Actions ve image build	Production onayı/staging tam değil	Ayrı staging, migration/release kapısı	Yüksek
SEO	robots, sitemap, canonical, OG	Public içerik SPA render	İçerik büyürse prerender/SSG	Orta

SQL injection riski JPA/parametrelili sorgularla düşüktür; native/dinamik sorgular yine incelemeye tabidir. React kaçışı XSS riskini azaltır; kullanıcı HTML'i render edilirse sanitize şarttır. Cookie kullanan endpoint'lerde CSRF/Origin yaklaşımı regresyon testinde tutulmalı; CORS dar domain listesi olmalıdır.

3. Otizm Platformuna Özel Güvenlik ve Gizlilik

Sağlık verisi KVKK'da özel nitelikli kişisel veridir ve daha sıkı korunmalıdır.¹ Çocuk adı, doğum tarihi, fotoğrafı, gelişim notu, tarama sonucu, ilaç kaydı, uzman mesajı ve yüklenen raporlar varsayılan olarak özel olmalıdır.

Zorunlu veri yönetiřimi

- Her veri alanı için amaç, hukuki işleme şartı, alıcı, ülke, saklama ve silme yöntemi yazılmalı.
- Veli/yasal temsilci ilişkisi doğrulanmalı; çocuğun yüksek yararı ve yaşına uygun bilgilendirme gözetilmeli.
- Profil, çocuk, fotoğraf ve gelişim kaydı varsayılan olarak kapalı; paylaşım granüler, süreli ve geri alınabilir olmalı.
- Uzmanla paylaşım yalnız seçilen veri sınıfları için; iptal sonrası yeni erişim kapanmalı ve audit'e düşmeli.
- Mesaj/dosya içeriği log, analitik, push payload ve e-postaya taşınmamalı.
- Hesap silme DB, nesne depolama, arama/cache ve sonraki yedek geri dönüş prosedürünü kapsamalı.²
- Yabancı bulut, Sentry, e-posta ve Gemini veri aktarımı; güncel KVKK m.9 mekanizması açısından hukukçu tarafından incelenmeli.
- Ana faaliyet özel nitelikli veri işlemeyse küçük işletme VERBİS istisnası otomatik varsayılmamalı; Kurumun güncel kriteri ayrıca değerlendirilmelidir.³

Tıbbi uyarı özü: "Bu platform bilgilendirme ve takip amaçlıdır; tıbbi teşhis, tedavi veya acil sağlık hizmeti sunmaz. Sonuçlar profesyonel sağlık/egitim hizmetinin yerine geçmez. Acil durumda 112'yi arayın; teşhis ve tedavi için yetkili uzmana başvurun." Bu uyarı chatbot, tarama sonucu, gelişim grafiği ve BEP taslağında görünür olmalı; son metni hukuk ve alan uzmanı onaylamalıdır.

4. Erişilebilirlik

Hedef **WCAG 2.2 AA** olmalıdır. Otomatik axe kontrolleri iyi bir kapıdır, fakat kontrast, bilişsel yük, odak sırası, ekran okuyucu anonsu ve hata anlaşılabilirliği manuel doğrulama gerektirir.

Kontrol	Mevcut durum	Kalan iş	Öncelik
Klavye/odak	Rota odağı ve görünür focus yaklaşımı var	Modal, menü, chat ve tablo tam klavye turu	Yüksek
Ekran okuyucu	Semantik/ARIA kullanımı güçlü	NVDA+Firefox ve VoiceOver+Safari uçtan uca	Yüksek
Formlar	Label ve anlaşılır validation altyapısı	Hata özeti, ilk hataya odak, sade dil	Yüksek
Hareket	Global reduced-motion desteği	Tüm chart/chat animasyonlarını doğrula	Orta
Kontrast/zoom	Axe temel kontrol	%200–400 zoom, yüksek kontrast ve güneş ışığı testi	Yüksek
Dokunma	Responsive tasarım	En az 24x24 CSS px, tercihen 44x44 hedefler	Orta
Medya	İçerik sisteme bağlı	Video altyazı, ses transkripti, otomatik oynatma yok	İçerik varsa yüksek
Bilişsel erişim	Sade akış hedefi	Tek görev/ekran, açık başlık, jargon açıklaması, zaman baskısı yok	Yüksek

5. Fiyat Araştırması Yöntemi

Fiyatlar 15 Temmuz 2026'da sağlayıcıların resmî sayfalarından alınmıştır. Vergi durumu açık olmayan yabancı hizmetler **vergi hariç liste fiyatı**dır. Kampanya ve yenileme ayrılmış; kullanım bazlı hizmetlere formül/örnek verilmiştir. Satın alma günü checkout tekrar kontrol edilmelidir.

TCMB'nin 14 Temmuz 2026 satış kurları kullanıldı: **USD 47,0098 TL, EUR 53,5755 TL.**⁴ Örnek: \$20 = 940,20 TL; €5,99 = 320,92 TL.

6. Frontend Yayınlama

Servis	Ücretsiz / başlangıç	Ücretli plan	Not	Karar
Cloudflare Pages	\$0	Pro aylık \$25 veya yıllık \$20/ay	Free: 500 build/ay; statik istek ve bant genişliği sınırsız	Önerilen ⁵
Vercel	Hobby \$0	Pro \$20/ay + kullanım	Hobby kişisel/non-commercial	Gerçek ürün için Pro ⁶
Netlify	Free \$0 / 300 kredi	Personal \$9; Pro \$20	Bant genişliği 20 kredi/GB, deploy 15 kredi	Kota izlenir ⁷
Firebase Hosting	10 GB depo ve yaklaşık 10 GB/ay transfer ücretsiz	yaklaşık \$0,026/GB depo, \$0,15/GB transfer	Ölçekte transfer pahalı	Alternatif ⁸
DO App Platform	3 statik app \$0	Container \$5/512 MB, \$10/1 GB, \$25/2 GB	Statik app başına 1 GiB transfer	Frontend kotası düşük ⁹
Render Static	\$0	Takım planına göre	TLS/CDN var	Alternatif ¹⁰

Cloudflare Pages Free yeterlidir. SPA fallback, preview/production env ayrımı ve `VITE_API_URL=https://api.alanadi` tanımlanmalıdır.

7. Backend Sunucu Maliyeti

Spring Boot + Redis için production tabanı **2 vCPU / 4 GB RAM** seçilmelidir.

Sağlayıcı/paket	Liste fiyatı	TL/ay	Kaynak/yorum
Hetzner CX23 , 2 vCPU/4 GB/40 GB	€5,49 + €0,50 IPv4 = €5,99	321	15 Haziran 2026 yeni fiyatı ¹¹¹²
Hetzner CX33 , 4 vCPU/8 GB/80 GB	€8,49 + €0,50 IPv4 = €8,99	482	Önerilen
DigitalOcean Droplet 1 vCPU/2 GB	\$12	564	Sabit fiyat ¹³
DigitalOcean Droplet 2 vCPU/4 GB	\$24	1.128	Hetzner'den pahalı
AWS Lightsail 2 vCPU/2 GB/60 GB/3 TB	\$12	564	AWS içinde öngörülebilir ¹⁴
Render Starter 0,5 CPU/512 MB	\$7	329	JVM production için zayıf
Render Standard 1 CPU/2 GB	\$25	1.175	Yönetim kolay ¹⁵
Railway	5/20 plan asgarisi; \$10/GB RAM-ay + \$20/vCPU-ay	2 GB+0,5 CPU yaklaşık 1.410	Kullanım değişken ¹⁶
Fly shared 1 GB	bölgeye göre yaklaşık \$5,92	278	Volume ayrıca; yeni kullanıcıya kalıcı free yok ¹⁷
Natro XCloud Medium 2 vCPU/4 GB	ilk 3 ay \$9,99; sayfada normal \$31,49	470 → 1.480	Kampanya/yenileme teyidi ¹⁸
Turhost VPS TR	6 aylık kampanyada aylık gösterim \$6,99	329	Dönem toplamı ve yenileme teyidi ¹⁹

Eski `cx22` €3,79 / `cx32` €6,80 fiyatları 15 Haziran 2026 sonrası güncel değildir. AWS EC2, GCP ve Azure bölge, disk, trafik ve taahhüde göre hesaplanır; tek sabit rakam verilmesi yanıltıcıdır.

Aylık aktif kullanıcı	Tahmini uygulama kaynağı	Mimari not
100	2 vCPU/4 GB, tek instance	VPS içi DB mümkün, off-site yedek şart
1.000	2–4 vCPU/4–8 GB	Managed DB önerilir
10.000	4 vCPU/8 GB veya 2 küçük replica	Cache, pool ve yük testi
50.000	En az 2x4 vCPU/8 GB + load balancer	HA DB/failover, ölçerek boyutlandırma

8. PostgreSQL Maliyeti

Servis	Ücretsiz	Ücretli başlangıç	Yedek/karar
Neon	0,5 GB, proje başına 100 CU-saat	Launch kullanım bazlı; tipik aralıklı 1 GB örneği \$15/ay	7 gün time travel; branch için iyi ²⁰
Supabase	500 MB, shared 500 MB RAM; pasiflikte durabilir	Pro \$25/ay, 8 GB disk	Günlük yedek/7 gün ²¹
DO Managed PostgreSQL	Yok	1 GB/10 GB \$15,15 ; 2 GB \$30,45; 4 GB \$60,90	Sabit bütçe için önerilen ²²
Render PostgreSQL	256 MB yalnız 30 gün	Basic 256 MB \$6; 1 GB \$19; Pro 4 GB \$55	Free production değil ²³
Railway PostgreSQL	Plan kredisi	RAM/CPU/disk kullanım bazlı	Demo/staging
AWS RDS	Yeni müşteri plan/kredi koşulları	Bölge+instance+disk+Multi-AZ hesaplayıcı	Büyük ölçekte güçlü ²⁴
VPS içi PostgreSQL	Ek lisans \$0	VPS'e dahil	Yedek/PITR/failover sizin sorumluluğunuzda

Minimum bütçede VPS içi PostgreSQL + günlük şifreli off-site yedek; profesyonel başlangıçta DO Managed \$15,15 veya Neon Launch önerilir. Üç ayda bir temiz ortama restore testi yapılmalıdır.

9. Alan Adı ve DNS

Kayıt kuruluşu	Uzantı	İlk yıl	Yenileme	TL/not
Cloudflare Registrar	Desteklenen gTLD	Registry + ICANN maliyeti; kâr payı yok	Aynı maliyet ilkesi	Kesin fiyat anlık domain-check/checkout; WHOIS redaction ve DNSSEC ücretsiz ²⁵
Namecheap	.com	\$11,28 + \$0,20 ICANN	\$18,48 + \$0,20	540 TL → 878 TL ²⁶²⁷
Squarespace	.com / .org	\$20	\$20	940 TL/yıl ²⁸
Turhost	.com	kampanya \$2,90	\$21,99	136 TL → 1.034 TL ²⁹
Turhost	.com.tr	kampanya \$1,49	\$14,99	70 TL → 705 TL
Natro	.com	yeni üyeye \$2,99	\$22,99	141 TL → 1.081 TL ³⁰
Natro	.com.tr	\$1,49	\$19,99	70 TL → 940 TL
Güzel Hosting	.com	\$8,99	Sayfada ayrı değil	423 TL + %20 KDV ; checkout teyidi ³¹
Güzel Hosting	.com.tr / .org.tr	99,90 TL	Sayfada ayrı değil	+ %20 KDV ; checkout teyidi
Veridyen	.com	634,99 TL	Satın alma adımıda teyit	Yerel TL fatura ³²
Veridyen	.com.tr	134,99 TL	Satın alma adımıda teyit	Yerel TL fatura

.com evrensel; .com.tr Türkiye hedef kitlesinde yerel güven verir. .org / .org.tr, işletmeci gerçekten STK değilse yanlış beklenti yaratabilir. Uygun seçim: Türkiye odaklıysa birincil .com.tr + koruma için .com; global plan varsa tersi.

TRABİS'e göre .com.tr, .net.tr, .org.tr 14 Eylül 2022'den beri belgesiz, ilk gelen ilk alır yöntemiyle tahsis edilir. .av.tr, .bel.tr, .dr.tr, .edu.tr, .gov.tr, .k12.tr, .kep.tr, .pol.tr, .tsk.tr belge/uygunluk kontrolüne tabidir.³³³⁴

Satın alma öncesi marka araştırması; sonrasında registrar MFA, transfer lock, otomatik yenileme, DNSSEC, iki yönetici ve kurtarma kodu şarttır. DNS için Cloudflare Free yeterlidir.

10. SSL, CDN, WAF ve Bot Koruması

Bileşen	Başlangıç seçimi	Maliyet	Not
TLS	Let's Encrypt / Cloudflare Universal SSL	\$0	Ücretli DV ek güven sağlamaz
DNS/CDN/temel DDoS	Cloudflare Free	\$0	Başlangıç için yeterli
Cloudflare Pro	Yalnız ölçülen ihtiyaçta	\$25/ay aylık veya \$20/ay yıllık	WAF/performans ihtiyacında ³⁵
Turnstile	Free	\$0	20 widget, widget başına 10 hostname, sınırsız challenge ³⁶
Rate limit	Redis tabanlı uygulama kontrolü	Redis'e dahil	Proxy IP zinciri doğru olmalı

Cloudflare Full (strict), DNSSEC ve CAA; origin'de dar firewall; uygulamada HSTS, CSP, frame-ancestors, nosniff, Referrer-Policy ve dar Permissions-Policy kullanılmalıdır. HSTS kısa süreyle denenip kademeli uzatılmalıdır.

11. Dosya ve Görsel Depolama

Servis	Ücretsiz kota	Ücretli fiyat	100 GB örneği	Karar
Cloudflare R2	10 GB-ay; 1 M Class A, 10 M Class B; egress \$0	\$0,015/GB-ay; A \$4,50/M, B \$0,36/M	kotasız kısım yaklaşık \$1,35/ay + istek	Canlı dosya ³⁷
Backblaze B2	İlk 10 GB	\$6,95/TB-ay; egress depolamanın 3 katına kadar free, sonra \$0,01/GB	yaklaşık \$0,63/ay	İkinci yedek ³⁸
DO Spaces	Yok	\$5/ay: 250 GiB + 1 TiB outbound	\$5/ay	Sabit bütçe ³⁹
AWS S3 Standard	Hesap koşuluna bağlı	yaygın bölgede yaklaşık \$0,023/GB-ay; request/egress ayrıca	\$2,30 + işlem/egress	Kurumsal/karmaşık ⁴⁰

Servis	Ücretsiz kota	Ücretli fiyat	100 GB örneği	Karar
Supabase Storage	1 GB	Pro \$25 içinde 100 GB; sonrası \$0,0213/GB	Paket içinde	Supabase seçilirse
Cloudinary	25 kredi	Plus \$99/ay veya yıllık \$89/ay	Kredi bazlı	Ağır medya dönüşümü ⁴¹

Bucket public olmamalı. İndirme backend'in kullanıcı/çocuk/konuşma kapsam kontrolünden sonra yapılmalı. UUID nesne adı, MIME+uzantı+magic-byte, boyut ve malware taraması; `private`, `no-store`; lifecycle ve silme kuyruğu kullanılmalıdır.

Sağlık raporu veya çocuk belgesi Gemini'ye doğrudan gönderilmemeli. Böyle bir akış açılırsa anonimleştirme, veri minimizasyonu, ücretli/veri eğitimi dışı API koşulu ve yurt dışı aktarım mekanizması hukukçu tarafından onaylanmalıdır.

12. E-posta, Push ve Yapay Zekâ

12.1 İşlemsel e-posta

Servis	Ücretsiz	Ücretli başlangıç	10.000 e-posta	Karar
Brevo	300/gün	Starter \$9/ay: 5.000/ay	Üst kota gerekir	Başlangıç SMTP ⁴²
Resend	3.000/ay, 100/gün	Pro \$20: 50.000; aşım \$0,90/1.000	\$20	Geliştirici deneyimi ⁴³
Postmark	Developer 100/ay	Basic \$15: 10.000	\$15	Teslimat odaklı ⁴⁴
Mailgun	100/gün	Basic \$15: 10.000; Foundation \$35: 50.000	\$15	SMTP/API ⁴⁵
Amazon SES	İlk 12 ay koşullu 3.000 message-charge/ay	\$0,10/1.000 outbound + \$0,12/GB ek	yaklaşık \$1 + veri	En ucuz, kurulum zor ⁴⁶
SendGrid	60 gün 100/gün deneme	Güncel plan dashboard'da	Kesin değil	Satın alırken teyit ⁴⁷

Spring Mail nedeniyle sağlayıcı çoğunlukla environment ile değişir. SPF, DKIM, DMARC, bounce/complaint webhook ve gönderim rate limit zorunludur. E-postada sağlık verisi/çocuk adı bulunmamalıdır.

12.2 Push

Firebase Cloud Messaging ve Web Push/VAPID ürün maliyeti **\$0**dır. FCM ücretsiz ürün grubundadır; varsayılan proje kotası dakikada 600 bin downstream mesajdır.⁴⁸ Push payload yalnız "Yeni bildiriminiz var" gibi genel metin taşımalıdır.

12.3 Gemini API

Kod `gemini-2.5-flash-lite` kullanıyor; model fiyatı Google'ın güncel tablosundan production günü yeniden sabitlenmelidir. 15 Temmuz 2026 sayfasında örneğin Gemini 3.5 Flash standard ücretli katman input için **1,50/1Mtoken** **, **output/thinking için *9/1M token** listeler. Ücretsiz katmanda içerik ürün geliştirmede kullanılabilir; ücretli katmanda kullanılmadığı belirtilir.⁴⁹

Tahmini örnek: Ayda 10.000 sohbet × ortalama 1.000 input + 300 output token ve yukarıdaki fiyat varsayımıyla \$15 + 27 = **42/ay (1.974 TL)**. Gerçek 2.5 Flash-Lite fiyatı farklıdır. Token telemetrisi, aylık hard limit ve uyarı kurulmalı; sağlık verisi için ücretsiz katman kullanılmamalıdır.

13. Kimlik Doğrulama

Mevcut Spring Security + kısa JWT access token + dönen HttpOnly refresh cookie + BCrypt + e-posta doğrulama **korunmalıdır**.

Seçenek	Fiyat yaklaşımı	Etki	Karar
Mevcut Spring Security	Lisans \$0; ekip bakımı	Tam rol/veri kontrolü	Önerilen
Firebase Auth/Identity Platform	Spark 3.000 DAU; Blaze ilk 50.000 MAU free, sonrası \$0,0025–0,0055/MAU	MFA/SAML avantajı, migration	Alternatif ⁵⁰
Supabase Auth	Plana bağlı	DB+auth bağlılığı	Gereksiz
Auth0/Clerk	MAU/özellik bazlı; checkout hesaplayıcı	Kolay sosyal login	Şimdilik gereksiz
Keycloak	Yazılım \$0; ayrı sunucu/bakım	En yüksek operasyon	Bu ölçekte gereksiz

Uzman rolü yalnız admin doğrulamasından sonra açılmalı; genel kayıt endpoint'i ayrıcalıklı rol verememelidir. Admin için TOTP/WebAuthn MFA yüksek önceliklidir.

14. Yönetim Paneli

Panel mevcut frontend içinde lazy-load edilen, frontend ve backend rol kontrolüyle korunan bölümdür. Kullanıcı/pasifleştirme, uzman onayı, içerik, şikâyet, audit log, istatistik ve ayar ekranları vardır. Ayrı admin projesi ek güvenlik sağlamaz; ek deployment ve sürüm uyumsuzluğu üretir.

Production kontrolleri: admin MFA ve kısa oturum; hassas işlem audit'i; en az yetki; toplu dışa aktarma/silmede ikinci onay; destek personeline tüm dosyaları gezme yetkisi vermeme; uzman belge erişimini saklama politikasına bağlama. Ek hosting maliyeti **\$0**dır.

15. Analitik, Loglama ve Hata Takibi

Servis	Ücretsiz	Ücretli	Öneri
Sentry	1 kullanıcı; 5.000 hata; 5 GB log; 5 M span; 50 replay	Team \$26/ay yıllık; Business \$80	Free başla, PII scrub ⁵¹
UptimeRobot	50 monitor, 5 dk	Solo yıllık \$9/ay, aylık \$10	Free yeterli ⁵²
Plausible	Cloud free yok	Starter \$9/ay/10 bin pageview; Growth \$14; Business \$19	Gizlilik odaklı ⁵³
Better Stack	10 monitor, 100 bin exception, 3 GB/3 gün log	Nano yıllık yaklaşık \$25/ay	Büyümede ⁵⁴
Prometheus/Grafana	Yazılım \$0	Sunucu/depo maliyeti	Backend metrikleri hazır
GA4/Search Console	\$0	\$0	GA4 rıza değerlendirmesi; GSC gerekli

Request body, Authorization/Cookie, e-posta, çocuk adı, tanı, ilaç, rapor, dosya ve AI prompt'u Sentry/loglara gönderilmemeli. Hata olayları correlation ID ile bağlanmalı; kullanıcıya stack trace dönmemelidir.

16. SEO, Performans ve Mobil

Kodda robots, sitemap, canonical, Open Graph, rota metadata; özel rotalarda `noindex`; lazy-loading; PWA manifest/service worker vardır.

- Gerçek domain alınınca sitemap/canonical/OG URL güncellenmeli.
- Halka açık bilgi/makale sayfaları büyürse prerender/SSG kullanılmalı; auth arkası render edilmemeli.
- Lighthouse CI hedefleri: performans ≥ 90 , erişilebilirlik ≥ 95 , SEO ≥ 95 ; düşük seviye Android'de de ölçülmeli.
- WebP/AVIF, ölçülü görsel ve lazy-load; sistem/yerel font yaklaşımı korunmalı.
- İki domain varyantı Search Console'a eklenip tek canonical'a 301 yönlendirilmeli.
- Service worker'ın API yanıtı veya hassas içerik cache'lemediği doğrulanmalı.

17. Yedekleme ve Felaket Kurtarma

Önerilen başlangıç hedefi **RPO 24 saat, RTO 4 saat**; büyümede RPO 1 saat/RTO 1 saat. İş sahibi bu hedefleri onaylamalıdır.

Veri	Sıklık	Hedef/saklama	Test
PostgreSQL mantıksal yedek	Günlük	AES-256 şifreli, farklı sağlayıcı; 30 günlük + 12 aylık	Aylık doğrulama, 3 ayda restore
Managed DB PITR	Sürekli/plan	Örn. 7 gün	3 ayda zaman noktasına dönüş

Veri	Sıklık	Hedef/saklama	Test
R2 dosyaları	Günlük manifest/versiyon	Farklı sağlayıcı B2	Hash ve rastgele dosya açma
Sunucu config	Her değişiklik	Özel Git/secrets vault	Yeni sunucuda kurulum
Encryption anahtarı	Her rotasyon	Offline ve erişim kontrollü	Restore DB'de decrypt testi

`backup-db.sh` ve `restore-db.sh` temel sağlar. Yedek production ile aynı disk/hesapta kalırsa felaket yedeği değildir. Silme talebi sonrası yedekten dönen kaydın tekrar silinmesini sağlayan prosedür gerekir.⁵⁵

18. Test ve Yayın Süreci

Son doğrulamada Docker gerektiren Testcontainers context testi hariç backend **92/92**, frontend Vitest **20/20**, Playwright/axe **8/8** geçti; lint, production build ve npm audit (0 açık) başarılıydı. Her release CI'da yeniden üretilmelidir.

Production kapısı	Başarı ölçütü
CI	Unit/integration, lint/build, dependency ve secret scan
Staging	Production benzeri Postgres/Redis/R2/SMTP; anonim veri
Güvenlik	ZAP kritik/yüksek yok; rol/upload negatif testleri
Performans	k6 ile p95 hedefi, hata <%1, heap/pool ölçümü
Erişilebilirlik	axe temiz; NVDA/VoiceOver kritik akışlar
Yedek	Temiz restore; DB-dosya referans bütünlüğü
Release	Migration/rollback, bakım duyurusu, manuel prod onayı
Gözlem	Health, uptime ve Sentry test alarmı; sorumlu kişi

Preview ortamı gerçek kullanıcı verisine bağlanmamalı; staging ve production ayrı secret, DB, bucket ve mail domaini kullanılmalıdır.

19. Önerilen Yapının Toplam Maliyeti

1.000–10.000 aylık aktif kullanıcı için başlangıç bütçesi; vergi ve insan emeği hariçtir.

Hizmet	Seçim	Aylık TL	Yıllık TL	Durum
Alan adı	Veridyen .com 634,99 TL/yıl	52,92	634,99	Zorunlu
DNS/CDN/TLS/Turnstile	Cloudflare Free	0	0	Zorunlu
Frontend	Cloudflare Pages	0	0	Zorunlu
Backend	Hetzner CX33 + IPv4 €8,99	481,65	5.779,80	Zorunlu

Hizmet	Seçim	Aylık TL	Yıllık TL	Durum
PostgreSQL	DO Managed 1 GB \$15,15	712,20	8.546,40	Önerilen
Redis	VPS üzerinde	0	0	Zorunlu
Dosya	R2 ilk 10 GB	0	0	Zorunlu
E-posta	Brevo Free	0	0	Zorunlu
Uptime/hata	UptimeRobot + Sentry Free	0	0	Zorunlu
Analitik	Plausible Starter \$9	423,09	5.077,08	Opsiyonel
AI	\$0-42 ölçüm tavanı	0-1.974,41	0-23.692,92	Kullanılırsa
Off-site yedek	R2/B2 free kota varsayımı	0	0	Zorunlu
Toplam; AI/Plausible hariç		1.246,77	14.961,19	
Toplam; Plausible + \$42 AI		3.644,27	43.731,21	

KVKK avukatı, sızma testi ve erişilebilirlik uzmanı için tek resmî piyasa tarifesı yoktur. Kapsam dokümanıylı en az üç yazılı teklif alınmalı; bu kalemleri sıfır kabul etmemek gerekir.

20. Üç Bütçe Senaryosu

A — Minimum güvenli başlangıç, yaklaşık 100-1.000 MAU

Cloudflare ücretsiz katmanları; Hetzner CX23; PostgreSQL+Redis aynı VPS; R2/B2 ve Brevo free; Veridyen .com; AI kapalı veya \$5/ay hard limit.

- **AI hariç:** yaklaşık **374 TL/ay, 4.487 TL/yıl**.
- **AI \$5 tavanıyla:** yaklaşık **609 TL/ay, 7.307 TL/yıl**.
- Risk: uygulama ve DB tek sunucuda; off-site yedek/restore şart.

B — Önerilen profesyonel, yaklaşık 1.000-10.000 MAU

Hetzner CX33; DO Managed PostgreSQL \$15,15; Redis VPS; Cloudflare Pages/R2; ücretsiz izleme; Plausible opsiyonel.

- **AI/Plausible hariç:** **1.247 TL/ay, 14.961 TL/yıl**.
- **Plausible + AI \$10 tavanıyla:** yaklaşık **2.140 TL/ay, 25.679 TL/yıl**.
- **AI \$42 tavanında:** Plausible dahil **3.644 TL/ay**.

C — Büyüyen platform, yaklaşık 10.000-50.000 MAU

En az 2x CX33, load balancer, staging CX23; 4 GB managed PostgreSQL \$60,90; Sentry Team \$26; Plausible Growth \$14; Resend \$20; Better Stack yaklaşık \$25; R2 yaklaşık \$5; AI \$25-100 tavan.

- **Tahmini:** **\$204-279/ay = 9.600-13.100 TL/ay**.
- **Yıllık:** yaklaşık **115.000-158.000 TL**.

- Load balancer, HA standby, yüksek egress, vergi ve insan operasyonu ayrıca; yük testi sonrası teklif yenilenmelidir.

21. Satın Alma Kararı

Kalem	Birincil öneri	Alternatif koşulu
Domain	Yerel TL fatura için Veridyen; gTLD şeffaflığı için Cloudflare Registrar	.tr desteği ve checkout fiyatı
DNS/CDN/TLS	Cloudflare Free	Özel WAF/SLA ölçülürse Pro
Frontend	Cloudflare Pages	Kurumsal süreç Vercel gerektirirse Pro
Backend	Hetzner CX33	Sunucu yönetilmeyecekse Render/DO App Platform
PostgreSQL	DO Managed \$15,15	Branch/scale-to-zero için Neon; minimumda VPS
Dosya	R2	B2 ikinci kopya; Spaces sabit 250 GB
E-posta	Brevo → hacimde Resend/Postmark/SES	Teslimat ve destek ölçümüne göre
Auth	Mevcut Spring Security	SAML/federasyon gerçek ihtiyaçta
İzleme	Sentry/UptimeRobot Free + Prometheus	Ekip/hacim büyüyünce ücretli
Analitik	Plausible veya yalnız Search Console	GA4 rıza tasarımı onaylanırsa

Tüm hesaplar kurumsal e-posta, MFA, iki yönetici, fatura bilgisi, kurtarma kodu ve devir prosedürüyle açılmalıdır.

22. Adım Adım Yayın Planı

#	İş	Süre	Maliyet	Çıkış ölçütü
1	Veri envanteri/işleme amacı/saklama/ülke haritası	2–5 gün	İç ekip+hukuk	İmzalı envanter
2	KVKK/çocuk/AI metni ve VERBİS değerlendirmesi	1–3 hafta	Teklif	Onaylı süreç
3	Domain ve kurumsal hesaplar/MFA	1 gün	Domain	Sahiplik/kurtarma
4	Production secret/vault	0,5 gün	\$0+	Dev varsayılını yok
5	Private R2, CORS, lifecycle, servis hesabı	0,5–1 gün	Kota içinde \$0	Yetkisiz 401/403
6	SMTP SPF/DKIM/DMARC/bounce	1–2 gün	\$0 başlangıç	Gmail/Outlook teslim
7	DB ve Flyway V1–V48	1 gün	Senaryoya göre	Validate/health 200
8	VPS hardening/Docker/firewall/SSH/log rotation	1–2 gün	VPS	Port/patch kontrolü
9	Backend, api. DNS, TLS, CORS/cookie	1 gün	\$0 ek	Auth/upload e2e

#	İş	Süre	Maliyet	Çıkış ölçütü
10	Pages, SPA fallback, env ayrımı	0,5 gün	\$0	Deep linkler 200
11	Turnstile ve proxy/rate limit	0,5 gün	\$0	Bot/429 negatif test
12	Off-site yedek ve temiz restore	1 gün	Küçük/\$0	RPO/RTO kanıtı
13	Sentry scrub/Uptime/Prometheus alarm	1 gün	\$0	Test alarmı ulaşıyor
14	ZAP/k6/dependency/secret scan	2-5 gün	İç ekip/teklif	Kritik-yüksek yok
15	NVDA/VoiceOver/gerçek mobil	1-3 gün	İç ekip/uzman	Kritik akışlar
16	Staging kabul; silme/dışa aktarma	1-2 gün	Küçük	İmzalı checklist
17	Production ve 24 saat yakın izleme	1 gün	—	SLO/hata normal

Mevcut hazırlıkla teknik süre yaklaşık **2-4 hafta**; hukuk ve bağımsız test tedarik süresi hariçtir.

23. Nihai Öneri

Katman	Seçim
Web	Cloudflare Pages Free
API	Hetzner CX33; büyümede 2 replica
DB	DO Managed PostgreSQL \$15,15; minimumda VPS içi
Cache	Redis aynı VPS; büyümede managed
Dosya	Private R2; B2 off-site
E-posta/push	Brevo SMTP + FCM/Web Push
AI	Ücretli/veri eğitimi dışı koşul, minimizasyon ve hard limit
Auth	Mevcut JWT; admin MFA
Güvenlik	Cloudflare Free + Turnstile + rate limit + strict TLS
Gözlem	Sentry, UptimeRobot, Prometheus/Grafana
CI/CD	GitHub Actions + ayrı staging + manuel prod onayı
Yedek	Günlük şifreli, farklı sağlayıcı; 3 ayda restore

Yayın öncesi zorunlu kalanlar

1. R2, SMTP, Turnstile, DNS ve production secret hesapları.
2. Off-site yedek ve temiz restore kanıtı.
3. Admin MFA ve kurumsal hesap sahipliği.
4. Gerçek domain üzerinde CORS/cookie/TLS/upload negatif testleri.
5. Çocuk, sağlık, rıza, aydınlatma, saklama, yurt dışı aktarım ve VERBİS için hukuk onayı.
6. AI'ya hassas veri gitmediğinin testi; gerekirse AI'yı production'da kapatma.
7. NVDA/VoiceOver ve bağımsız güvenlik testi.

Son karar: Kod tabanı güçlüdür; ana risk artık operasyon ve veri yönetiřimidir. En dengeli bařlangıç aylık yaklaşık **1.247 TL sabit altyapı**dır. Minimum yapı 374 TL/ay eřdeęerine iner, fakat DB ve uygulamayı aynı sunucuda tuttuęu iin daha risklidir.

Arařtırmanın Sınırları

- Uzak repo/canlı demo baęlantısı verilmedi; yerel alıřma aęacı incelendi.
- Fiyatlar bölge, vergi, kampanya ve ödeme dönemine göre deęiřebilir; checkout tekrarlanmalıdır.
- MAU kapasitesi tahmindir; production-benzeri yük testi ve telemetri belirleyicidir.
- Rapor hukuk, tıp, muhasebe veya baęımsız sızma testi görüşü deęildir.

Resmî Kaynaklar

1. KVKK Özel Nitelikli Veriler: <https://www.kvkk.gov.tr/Icerik/2051/Ozel-Nitelikli-Kisisel-Veriler>
2. KVKK Silme/Yok Etme/Anonimleştirme: <https://www.kvkk.gov.tr/Icerik/2038/kisisel-verilerin-silinmesi-yok-edilmesi-veya-anonim-hale-getirilmesi>
3. KVKK VERBİS İstisna Kriteri: <https://www.kvkk.gov.tr/Icerik/8388/KAMUOYU-DUYURUSU>
4. TCMB Günlük Döviz Kurları, 14.07.2026: <https://www.turkiye.gov.tr/doviz-kurlari>
5. Cloudflare Pages: <https://pages.cloudflare.com/>
6. Vercel Pricing: <https://vercel.com/pricing>
7. Netlify Pricing: <https://www.netlify.com/pricing/>
8. Firebase Hosting Pricing: <https://firebase.google.com/docs/hosting/usage-quotas-pricing>
9. DigitalOcean App Platform: <https://www.digitalocean.com/pricing/app-platform>
10. Render Pricing: <https://render.com/pricing>
11. Hetzner 15 June 2026 Price Adjustment: <https://docs.hetzner.com/general/others/price-adjustment/>
12. Hetzner Primary IP: <https://docs.hetzner.com/cloud/servers/primary-ips/overview/>
13. DigitalOcean Droplets: <https://www.digitalocean.com/pricing/droplets>
14. AWS Lightsail: <https://aws.amazon.com/lightsail/pricing/>
15. Render Pricing: <https://render.com/pricing>
16. Railway Pricing: <https://railway.com/pricing>
17. Fly.io Pricing: <https://fly.io/docs/about/pricing/>
18. Natro VPS: <https://www.natro.com/sunucu-kiralama/vps-cloud-server>
19. Turhost VPS TR: <https://www.turhost.com/sunucu/vps-tr-sunucu/>
20. Neon Pricing: <https://neon.com/pricing>
21. Supabase Pricing: <https://supabase.com/pricing>
22. DigitalOcean Managed Databases: <https://www.digitalocean.com/pricing/managed-databases>
23. Render Pricing: <https://render.com/pricing>
24. AWS RDS Pricing: <https://aws.amazon.com/rds/pricing/>
25. Cloudflare Registrar: <https://developers.cloudflare.com/registrar/>
26. Namecheap Domain Prices: <https://www.namecheap.com/domains/>
27. ICANN Fee: <https://www.namecheap.com/support/knowledgebase/article.aspx/1256/2201/what-is-the-icann-fee/>
28. Squarespace Domains: <https://support.squarespace.com/hc/en-us/articles/217963508-Starting-with-a-Squarespace-domain>
29. Turhost Domain Prices: <https://www.turhost.com/domain/domain-sorgulama/>
30. Natro Domain Prices: <https://www.natro.com/domain-sorgulama/domain-transfer>
31. Güzel Hosting Domain Prices: <https://www.guzel.net.tr/orderdomain.php>
32. Veridyen Domain Prices: <https://www.veridyen.com/domain/fiyatlar>

33. TRABİS Belgesiz Geçiş: <https://www.trabis.gov.tr/content/belgesizeGecis>
34. TRABİS Belgeli Tahsis: <https://www.trabis.gov.tr/content/Belgeli>
35. Cloudflare Pages: <https://pages.cloudflare.com/>
36. Cloudflare Turnstile Plans: <https://developers.cloudflare.com/turnstile/plans/>
37. Cloudflare R2 Pricing: <https://developers.cloudflare.com/r2/pricing/>
38. Backblaze B2 Pricing: <https://www.backblaze.com/cloud-storage/pricing>
39. DigitalOcean Spaces: <https://www.digitalocean.com/pricing/spaces-object-storage>
40. AWS S3 Pricing: <https://aws.amazon.com/s3/pricing/>
41. Cloudinary Pricing: <https://cloudinary.com/pricing>
42. Brevo Pricing: <https://www.brevo.com/pricing/>
43. Resend Pricing: <https://resend.com/pricing>
44. Postmark Pricing: <https://postmarkapp.com/pricing>
45. Mailgun Pricing: <https://www.mailgun.com/pricing/>
46. AWS SES Pricing: <https://aws.amazon.com/ses/pricing/>
47. SendGrid Pricing: <https://sendgrid.com/en-us/pricing>
48. Firebase No-cost Products: <https://firebase.google.com/docs/projects/billing/firebase-pricing-plans>
49. Gemini API Pricing: <https://ai.google.dev/gemini-api/docs/pricing>
50. Firebase Authentication Pricing: <https://firebase.google.com/docs/auth>
51. Sentry Pricing: <https://sentry.io/pricing/>
52. UptimeRobot Pricing: <https://uptimerobot.com/pricing/>
53. Plausible Pricing: <https://plausible.io/>
54. Better Stack Pricing: <https://betterstack.com/pricing>
55. KVKK Silme/Yok Etme/Anonimleştirme: <https://www.kvkk.gov.tr/Icerik/2038/kisisel-verilerin-silinmesi-yok-edilmesi-veya-anonim-hale-getirilmesi>